ISO/IEC 42001 Compliance Control Matrix

System profile used across this portfolio: FinanceGuard AI is a fine-tuned LLM used for financial document review. It processes PII and confidential financial data through an internal API gateway and operates across a hybrid cloud environment. Current-state evidence indicates incomplete data lineage, monitoring, impact assessment, adversarial testing, transparency, and retention enforcement. These assumptions drive the control ratings and the Conditional Go recommendation.

Control Reference	ISO/IEC 42001 Control Name & Domain	Control Objective & System Application	Implementation Status (Implemented/Partial/Gap)	Audit Evidence/Validation Artifact
Clause 6.1.2	AI Risk Assessment	Identify, analyze, and evaluate risks specific to the fine-tuned LLM processing confidential PII and financial data.	**Gap**	No approved AI risk register or algorithmic impact assessment. Create, approve, and review quarterly; link GAP-01 through GAP-03 and named treatment owners.
A.5.2	Data for AI Systems	Ensure data used for fine-tuning and validation is high quality, representative, and collected with appropriate data privacy boundaries.	**Gap**	No complete lineage or sanitization evidence. Produce source inventory, lineage map, classification, minimization, and deletion-test records.
A.6.2	Logging and Monitoring	Record system inputs, outputs, and runtime behaviors via the internal API gateway to detect anomalies or data exfiltration.	**Partial**	Some API-gateway capability is assumed, but end-to-end logging and review are unproven. Provide configs, log samples, alerts, tickets, and retention evidence.
A.7.2	AI System Impact Assessment	Assess the potential consequences of the automated document review system on internal stakeholders and regulatory filings.	**Gap**	No approved business, fairness, or regulatory impact assessment. Complete assessment and obtain AI Program Lead approval before scaling.

Control Reference	ISO/IEC 42001 Control Name & Domain	Control Objective & System Application	Implementation Status (Implemented/Partial/ Gap)	Audit Evidence/Validation Artifact
A.8.3	Security of AI Systems	Protect the fine-tuned LLM infrastructure from adversarial attacks, prompt injection, and unauthorized weights modification.	**Partial**	Baseline security controls exist but prompt-injection, adversarial, access, and model-integrity testing is incomplete. Provide reports and closure evidence.
A.9.2	AI System Transparency	Provide clear documentation and explanations of the model's capabilities, limitations, and intended use to internal analysts.	**Partial**	Model card, intended-use limits, and analyst training are incomplete. Approve documentation and retain training acknowledgements.

Status Definitions:

- **Implemented:** The control is fully functional, documented, and actively producing evidence (for example, active API logging).
- **Partial:** The control is partially designed or active but lacks complete documentation, enforcement, or consistent evidence generation.
- **Gap:** The control is missing entirely or fundamentally insufficient, creating immediate regulatory or operational risk.